

测试

- 有两串密码，你能破解吗？
 - kcocuvwfgpv
 - knqxgeqorwvgtuekgpeg



西安交通大学
XI'AN JIAOTONG UNIVERSITY

第七讲： 密码学与信息安全

师斌

School of Computer Science & Technology,
Xi'an Jiaotong University



电影《模仿游戏》片段

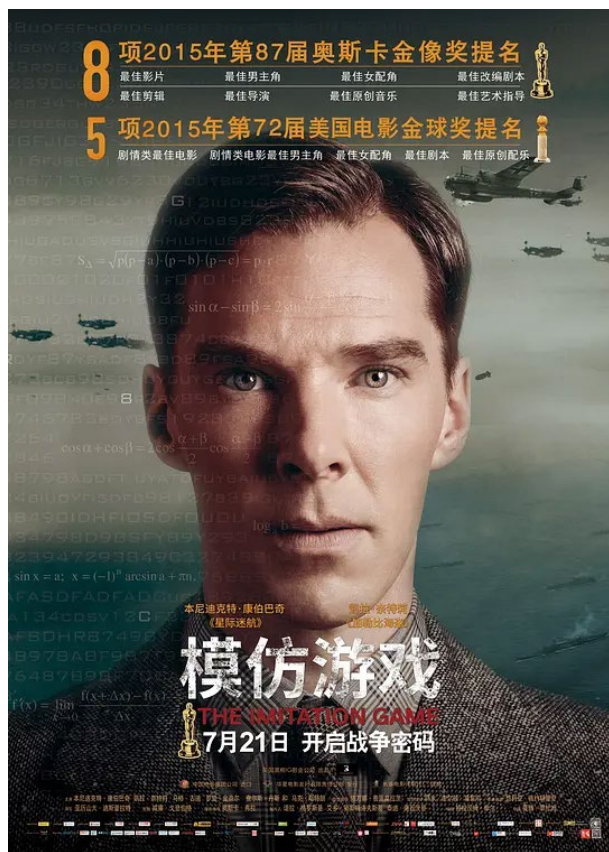


大肥货 bilibili



西安交通大学
XI'AN JIAOTONG UNIVERSITY

》电影《模仿游戏》



恩尼格玛机
或“谜”式密码机



- 改编自安德鲁·霍奇斯编著的传记《艾伦·图灵传》，讲述了“计算机科学之父”艾伦·图灵的传奇人生
- 聚焦于图灵协助盟军破译德国密码系统“恩尼格玛” (Enigma)，从而扭转二战战局的经历

» 主要内容

- **密码学概述**
 - 古代密码学
 - 现代密码学
- **信息安全**
 - 内涵与外沿
 - 安全威胁与防范

密码学

密码学 (Cryptology)

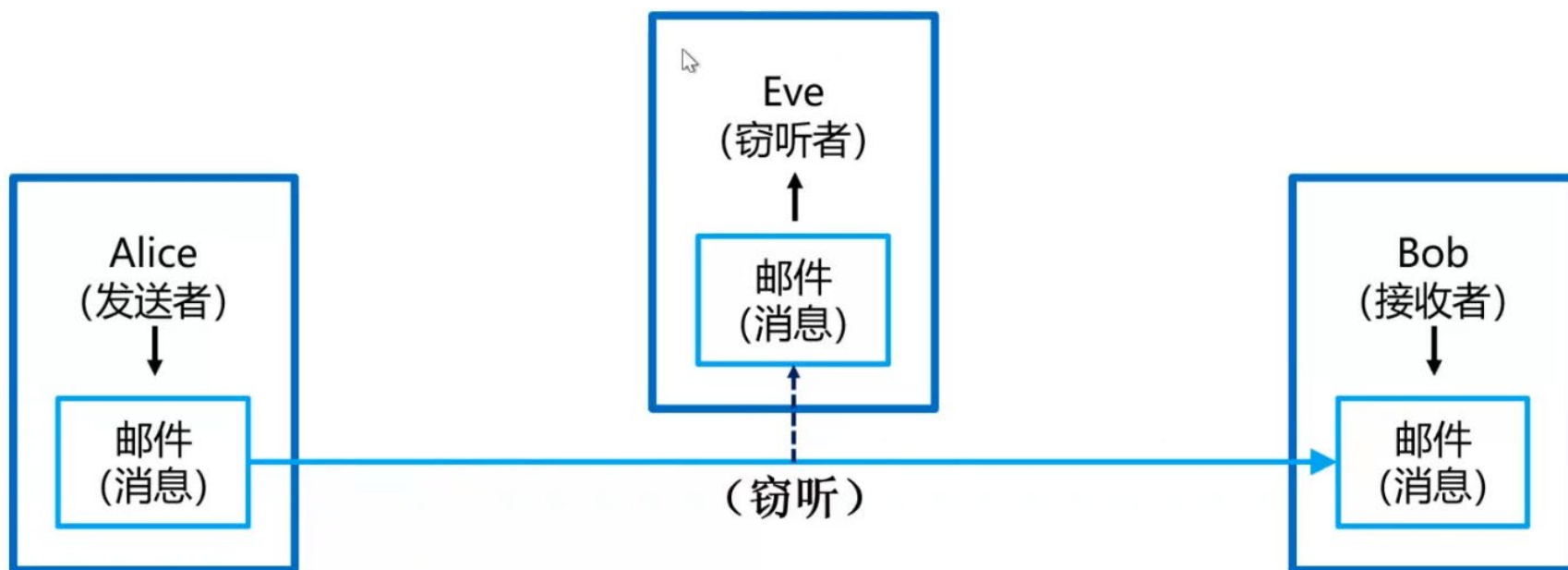
- 研究编制密码和破译密码的技术科学
- 数学和计算机科学的分支
 - 信息论
 - 计算复杂性理论
 - 统计学
 - 组合数学
 - 抽象代数数论
 -
- “密码学是关于如何在敌人存在的环境中通讯”

——罗纳德·李维斯特

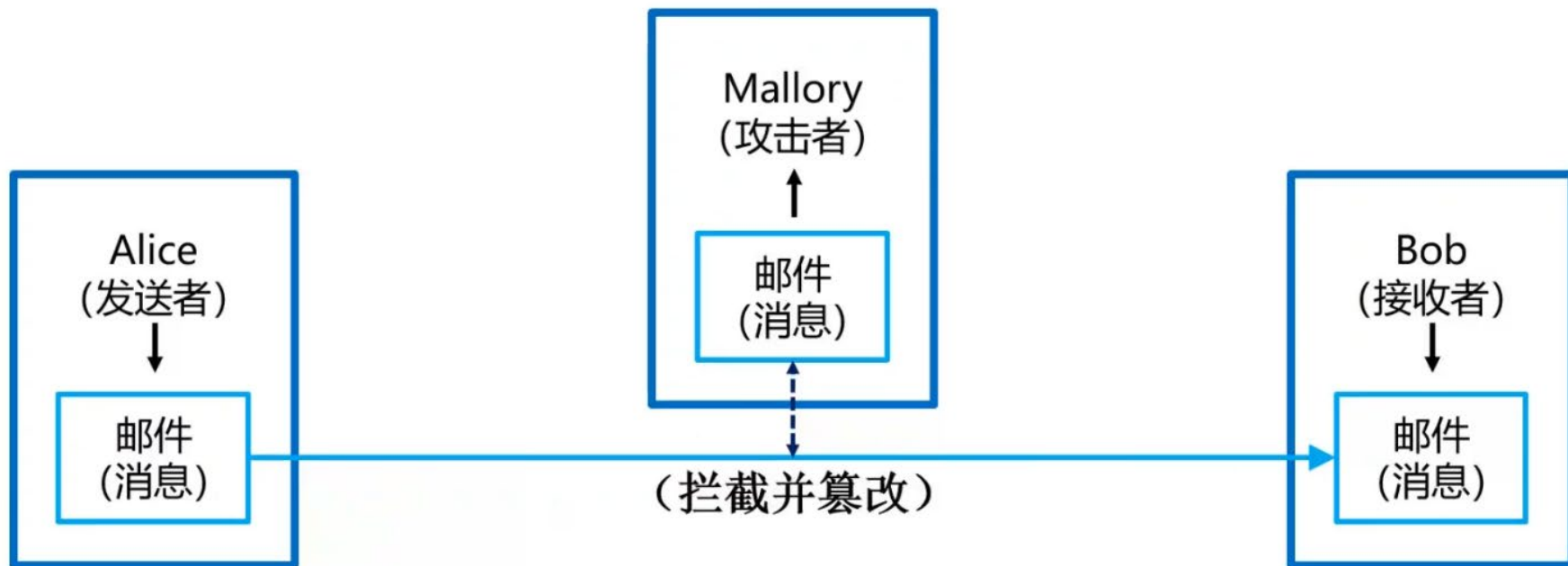


罗纳德·李维斯特
美国密码学家，2002年因在公钥密码学
RSA加密算法取得的杰出贡献而获得图灵奖

密码学保证消息的机密性 (Confidentiality)



保证消息的完整性（Integrity）、真实性（Authenticity）



» 主要内容

- **密码学概述**
 - 古代密码学
 - 现代密码学
- **信息安全**
 - 内涵与外沿
 - 安全威胁与防范

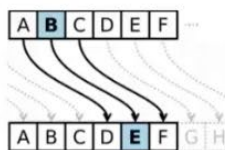
密码学

古典密码学与近代密码学

公元前5世纪

加密机械

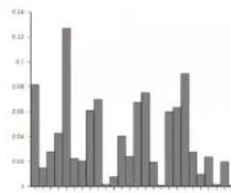
古希腊城邦斯巴达使用的人类历史上最早的加密机械：密码棒 (Scytale)



公元9世纪

频度分析

阿拉伯的密码学家提出解密的频度分析方法



1919

电子加密系统

德国发明家亚瑟·谢尔比乌斯发明了一种能够自动编码的机器恩格玛机 (ENIGMA)



公元前1世纪

替换加密

罗马共和时期凯撒使用的替换加密方式，使用的偏移量就是最早的文字密钥



1553

多表替换

意大利密码学家吉奥万·贝拉索 (Giovann B. Bellaso) 提出根据密钥来决定用哪一行的替换表

古典加密：对称加密的雏形，对称（双方共享密钥）
现实：古典密码都已经被破解



密码学

现代密码学

现代密码学开端： 公钥密码诞生

把密钥分为加密的私钥和解密的公钥。

优势：不需要双方提前共享密钥

安全性：从公钥难以推算出私钥

1976

Diffie-Hellman密钥交换 (图灵奖2015)

斯坦福大学惠特菲尔德·迪菲 (Bailey Diffie) 和马丁·赫尔曼 (Martin Hellman) 提出的第一个密钥交换算法



1986

多方安全计算 (图灵奖2000)

普林斯顿大学的姚期智提出的在无可信第三方情况下，能够安全地进行多方协同计算的理论框架

1975

数据加密标准 (DES)

美国国家标准局将Data Encryption Standard (DES)颁布为国家标准

1977

RSA算法 (图灵奖2002)

麻省理工学院的罗纳德·李维斯特 (Ron Rivest) 阿迪·萨莫尔 (Adi Shamir) 和伦纳德·阿德曼 (Leonard Adleman) 提出了第一个比较完善的公钥密码体制



姚期智 Andrew Yao

现代密码学

2005

容错学习问题 (哥德尔奖2018)

由 Oded Regev 在2005年提出。求解LWE问题的时间开销是指数级的，即使是对量子计算机也没有任何帮助，故LWE困难性被用作创建公钥密码系统



Oded Regev

2013

不可区分混淆 (iO) - 密码学皇冠上的明珠

是最有可能实现的安全混淆器。混淆后的程序与混淆前功能一样，并且无法从混淆代码中提取出任何有效信息（密钥、模型等）。iO可以用来保护机器学习的模型和算法。

2005

基于属性的加密 (ABE)

最先由Waters提出，是一种公钥加密方案。实现了加密数据的细粒度访问控制，即数据拥有者可以指定谁可以访问加密的数据，数据拥有者对数据具有完全的控制权

2009

全同态加密 (FHE)

IBM的Craig Gentry提出的同态加密算法。可以在没有密钥的情况下，把密文任意组合形成新的密文，并且新的密文可以完美的被还原成明文



Craig Gentry

密码学分类



» 主要内容

- **密码学概述**
 - **古代密码学**
 - **现代密码学**
- **信息安全**
 - **内涵与外沿**
 - **安全威胁与防范**

古代密码学

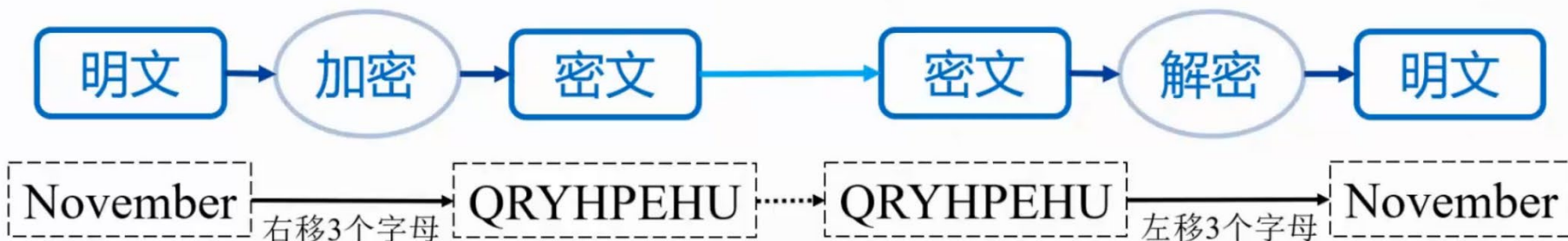
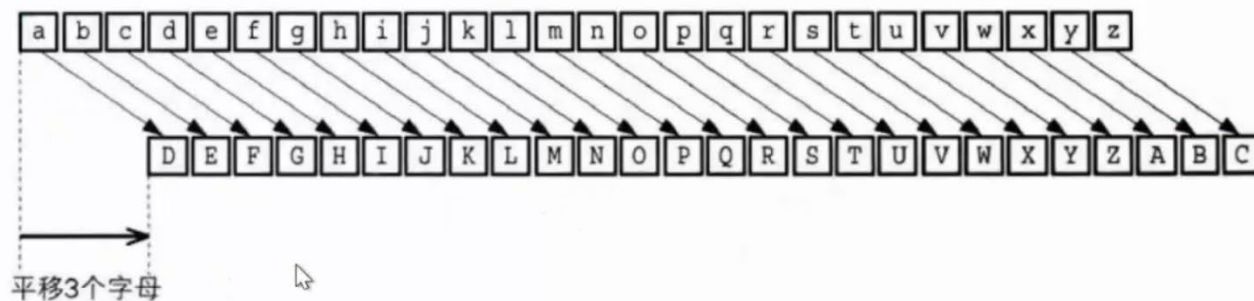
密码棒(Scytale, 希腊语)

- 古希腊的斯巴达人最早使用一根叫 Scytale的棍子进行加密。
- 送信人先绕棍子卷一张纸条，然后把要写的信息打纵写在上面，接着打开纸送给收信人。
- 如果不知道棍子的粗细是不能解密里面的内容的



古代密码学

凯撒密码



古代密码学

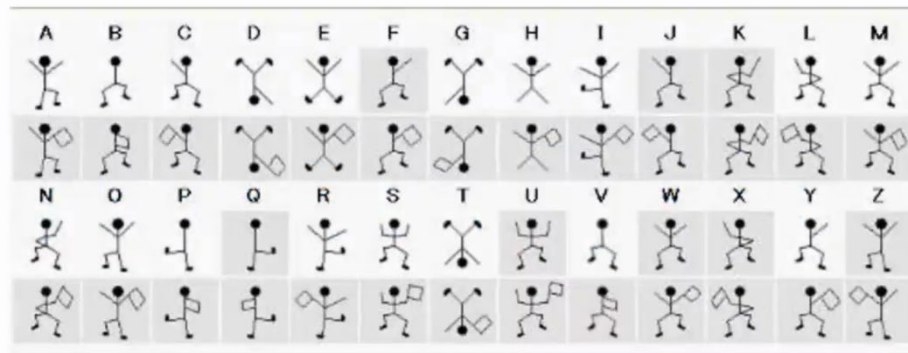
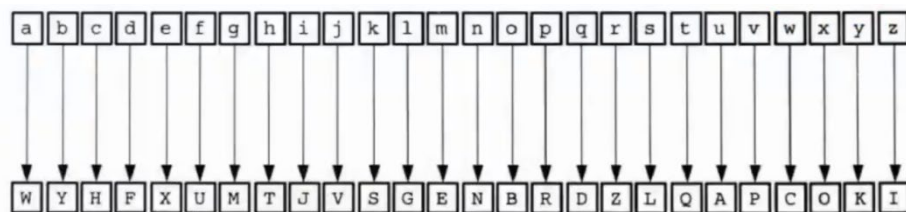
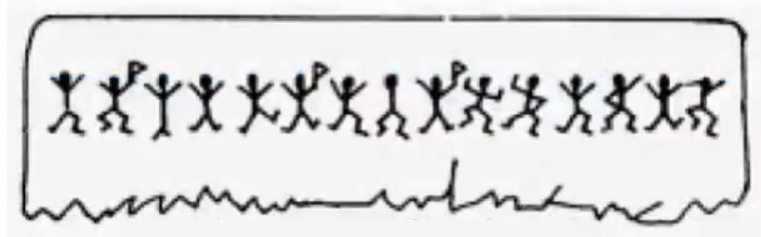
凯撒密码

- 有两串密码，你能破解吗？
 - kcocuvwfgpv
 - knqxcgeqorwvgtuekgpeg

古代密码学

单表替换密码

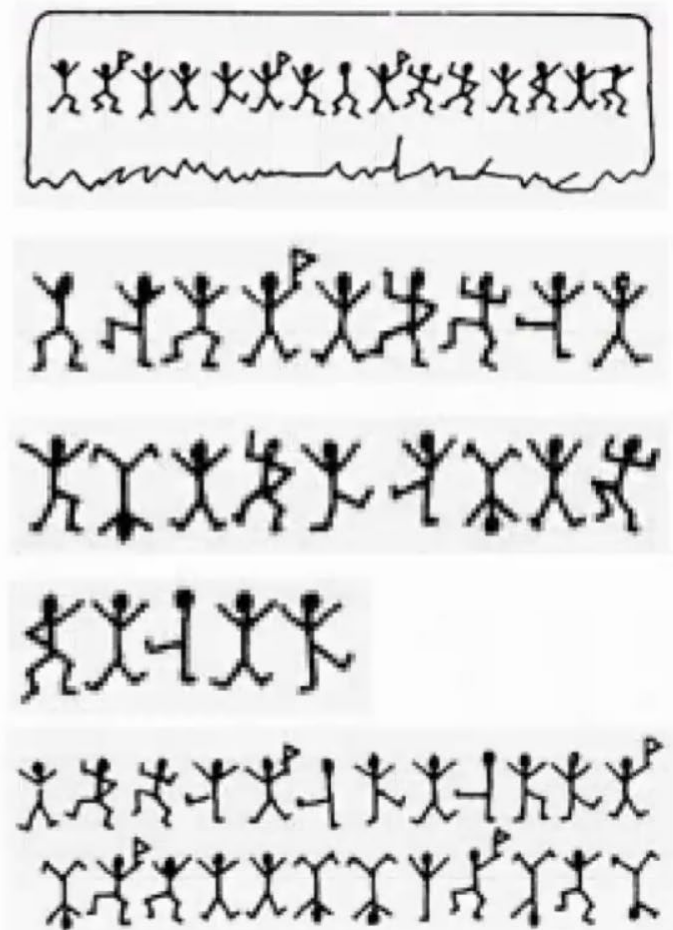
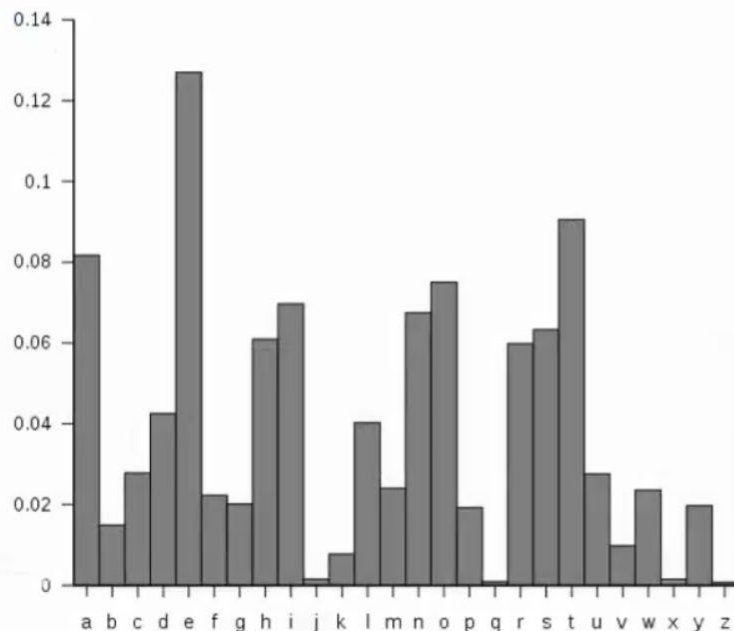
- 相比于凯撒密码使用了随机排列
- 《福尔摩斯跳舞的小人》
“的确是一件很难看懂的作品，”福尔摩斯说，“乍一看就象孩子们开的玩笑，在纸上横着画了些在跳舞的奇形怪状的小人。



古代密码学

单表替换密码的破解

- 破译方法：频率分析
 - 公元前9世纪阿拉伯的密码学家提出解密的频度分析方法



》》古代密码学

单表替换密码的破解

- “在交给我的第一张纸条上那句话很短，我只能稍有把握假定人代表E。你们也知道，在英文字母中E最常见，它出现的次数多到即使在一个短的句子中也是最常见”
- “大致说来，字母按出现次数排列的顺序是T, A, O, I, N, S, H, R, D, L;但是T, A, o, l, 出现的次数几乎不相上下”
- “当中有三个别的字母的组合很可能就是ELSIE(埃尔茜)这个名字。我一检查，发现这个组合曾经三次构成一句话的结尾。这一来我就找出了L、S和I”

古代密码学

多表替换密码(维吉尼亚密码)

- 16世纪意大利密码学家吉奥万·贝拉索(GiovanB.Bellaso)提出根据秘钥来决定用哪一行的替换表。
- $M[i]=Table[P[i]][S[i]]$

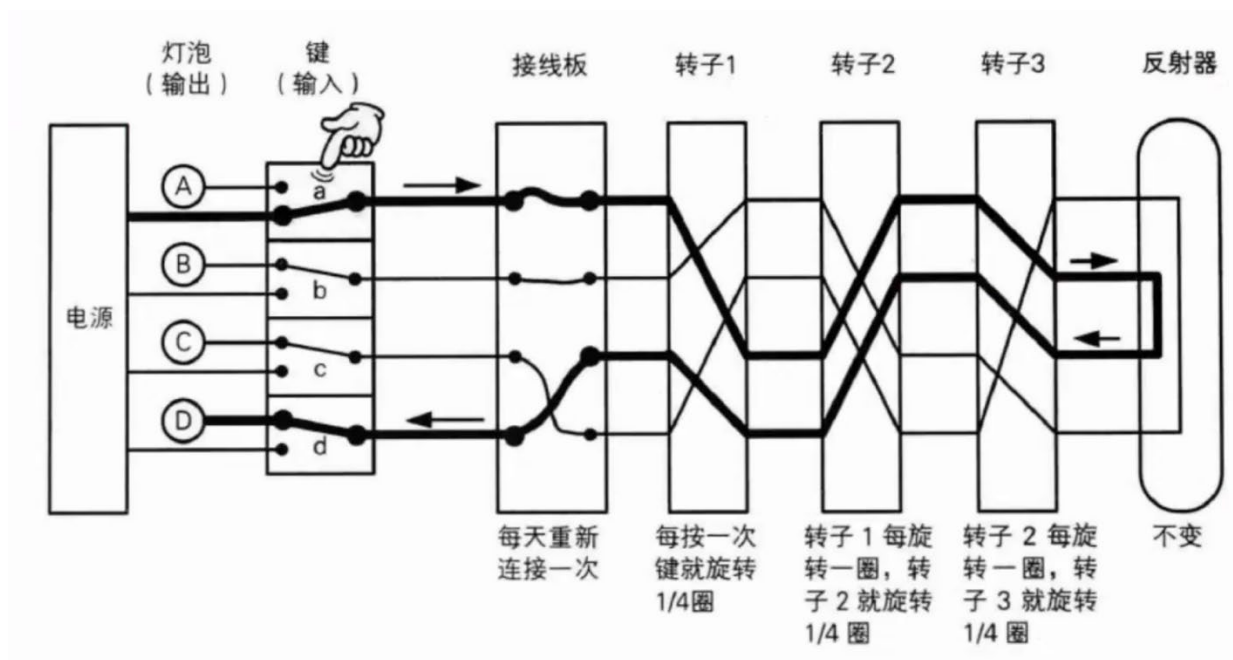
明文: A T T A C K A T D A W N
秘钥: L E M O N L E M O N L E
密文: L X F O P V E F R N H R

	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
A	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
B	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A
C	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B
D	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C
E	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D
F	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E
G	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F
H	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G
I	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H
J	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I
K	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J
L	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K
M	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L
N	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M
O	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N
P	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O
Q	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P
R	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q
S	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R
T	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S
U	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T
V	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U
W	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V
X	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W
Y	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X
Z	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y



古代密码学

恩格玛机(Enigma)



》》古代密码学

恩格玛机(Enigma)的破解

Ele实验室 bilibili

特别说明

炸弹机 (Bombe) 是英国人破解恩格玛机的重要基础，但炸弹机并不能直接得到结果，而是将需要'进一步分析'的转子初始位置和接线板规则的可能性减少到可管理的数字，然后配合人工手段进行破解。
Bombe有很多复杂的细节，本视频只讲述他最核心的破解思路

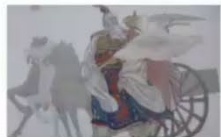
密码学

中国古代密码学

商朝末年

“阴书”、“阴符”

姜子牙设计，竖向书写，把一段信息分为三段，从不同路线、时间发出；通过纸条长度判别军方信息



三国时期

“拆字法”

三国时期民谣“千里草，何青青，十日卜，不得生”。其中“千里草”为“董”，“十日卜”为“卓”，暗指董卓作恶多端



明朝

戚继光“反切码”

取上字的声母和下字的韵母，“切”出另外一个字的读音，其原理与现代密电码的设计原理完全一样



春秋战国

《左传》“暗语”

春秋战国，楚国进攻萧国时候，楚国大夫申叔展与萧国大夫还无社有旧交，通过暗语战争结束还无社获救



唐朝

“拆字法”

唐朝徐敬业起兵反抗武则天，密信写道“青鹅”，其中“青”为“十二月”，“鹅”为“我自与”，意思为“起义在12月发起”



» 主要内容

- **密码学概述**
 - 古代密码学
 - **现代密码学**
- **信息安全**
 - 内涵与外沿
 - 安全威胁与防范

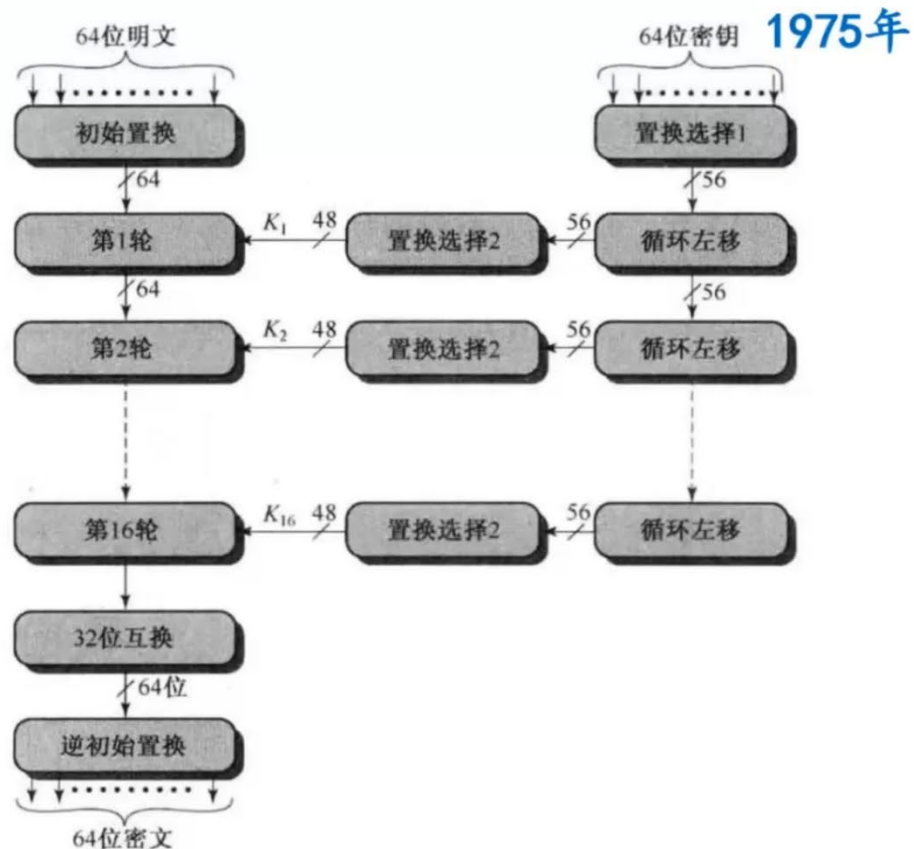
现代密码学

▪ 数据加密标准 (DES)

- 1977年称为美国联邦信息处理标准
- 64位的分组长度和56位的密钥长度
- 初始和末尾有一个置换
- 中间进行16轮Feistel函数

▪ 分组密码

- 以64bit的明文为一个单位进行加密
- 密钥通过固定的移位和置换函数产生16个子密钥



现代密码学：密码强度

- DES (Data Encryption Standard) 的强度
 - 56位密钥有 $2^{56} = 72057594037927936 \approx 7 \times 10^{16}$
- AES (Advanced Encryption Standard) 高级加密标准
 - 明文长度128位
 - 密钥长度128位, 192位, 256位
 - $2^{128} \approx 3 \times 10^{38}$ (一年有 3×10^7 秒)
- 美国罗拉多州的程序员Verser从1997年2月18日起, 用了96天时间, 在Internet上数万名志愿者的协同工作下, 成功地找到了DES的密钥, 赢得了悬赏的1万美元
- 1998年7月电子前沿基金会 (EFF) 使用一台25万美元的电脑在56小时内破译了56比特密钥的DES
- 1999年1月RSA数据安全会议期间, 电子前沿基金会用22小时15分钟就宣告破解了一个DES的密钥

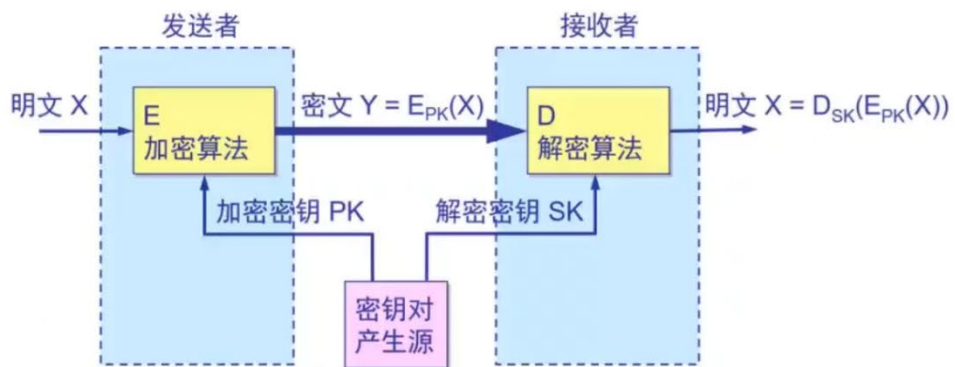
现代密码学

- 对称密码体制的缺陷
 - 加密密钥与相应的解密密钥相同
 - 消息的发送方和接收方必须在密文传输之前通过安全信道进行密钥传输
- 公钥加密体制
 - 将传统密码的密钥一分为二，分为加密密钥（公钥）和解密密钥（私钥）
 - 公钥是公开的，任何人都可获得
 - 私钥保密，需要妥善保存
 - 消息的发送方和接收方不再需要通过安全信道进行密钥传输

密码学

现代密码学：非对称加密

- 公开密钥密码体制使用**不同的加密密钥与解密密钥**，是一种“由已知加密密钥推导出解密密钥在计算上是不可行的”密码体制。
- 两个主要用途：一是解决常规密钥密码体制的密钥分配问题，另一是用于数字签名。
- 最著名的体制：**RSA 体制**，它基于数论中大数分解问题的体制，由美国三位科学家 Rivest, Shamir 和 Adleman 于 1976 年提出并在 1978 年正式发表的。



- 加密密钥(即公开密钥) PK 、加密算法 E 和解密算法 D 都是公开的，只有解密密钥(即秘密密钥) SK 是需要保密的
- 虽然秘密密钥 SK 是由公开密钥 PK 决定的，但却不能根据 PK 计算出 SK 。

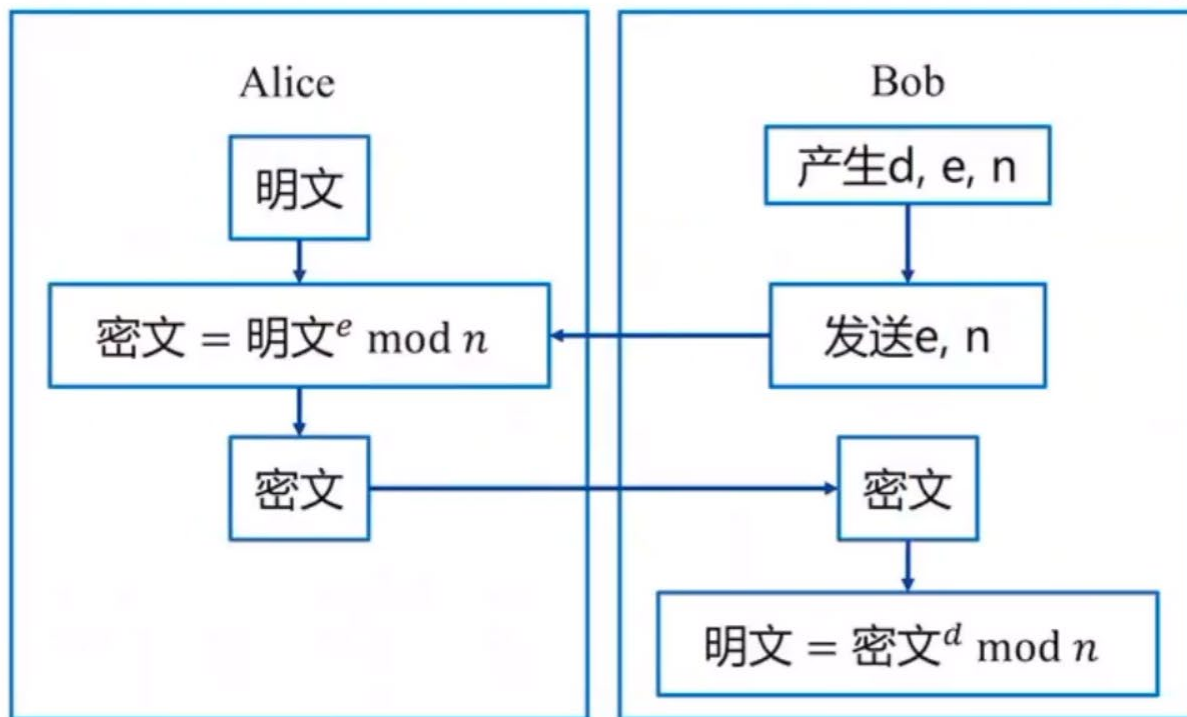
密码学

现代密码学：非对称加密

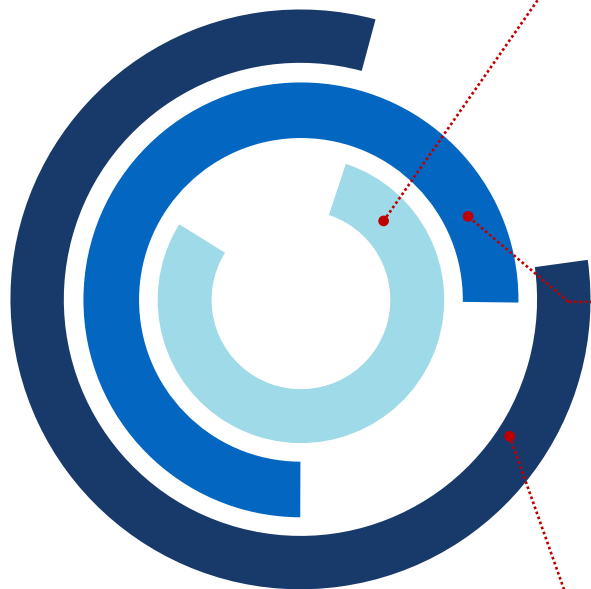
1978年

公钥密码：RSA算法

- 公钥：e和n
- 私钥：d和n
- Bob将公钥发给Alice
- Alice用公钥加密
- Alice发送密文
- Bob用私钥解密



现代密码学：非对称加密



贝祖定理：互质整数 a 、 b ， $ax + by = 1$ 一定有整数解

欧几里得算法，即辗转相除法：求最大公约数

扩展欧几里得算法：逆推欧几里得算法过程
获得贝祖定理所述方程的解

费马小定理：对质数 p ，整数 a 不是 p 的倍数，
则 $a^{p-1} \bmod p = 1$

现代密码学：非对称加密

公钥 (n, e) ：

选择大素数 p 、 q ，令 $n = pq$

再选择 e ， $e \in (1, (p-1)(q-1))$ 且 e 与 $(p-1)(q-1)$ 互质，
可由辗转相除法求得符合条件的 e 。

私钥 d ：

选择 d ， $ed \bmod (p-1)(q-1) = 1$

令 $(p-1)(q-1) = m$ ，上式可转化为

$ed - k(p-1)(q-1) = 1$ ，由于 e 与 $(p-1)(q-1)$ 互质，
由贝祖定理知此式有整数解，并可由扩展欧几里得算法求出，这样 d 就出来了。

密码学

现代密码学：非对称加密

加密：

$$C = P^e \bmod n$$

解密：

$$C^d \bmod n = ?$$

费马小定理：对质数 p ，
整数 a 不是 p 的倍数，
则 $a^{p-1} \bmod p = 1$

$$C^d \bmod n = (P^e \bmod n)^d \bmod n = P^{ed} \bmod n \quad (\text{模运算性质})$$

因为 $ed \bmod (p-1)(q-1) = 1$ ，等价于 $ed = k(p-1)(q-1) + 1$

带入前式，有 $C^d \bmod n = P * P^{k(p-1)(q-1)} \bmod n$

根据费马小定理，对于 $P^{(p-1)(q-1)}$ ，显然有

$$P^{(p-1)(q-1)} \bmod p = 1 \text{ 且 } P^{(p-1)(q-1)} \bmod q = 1$$

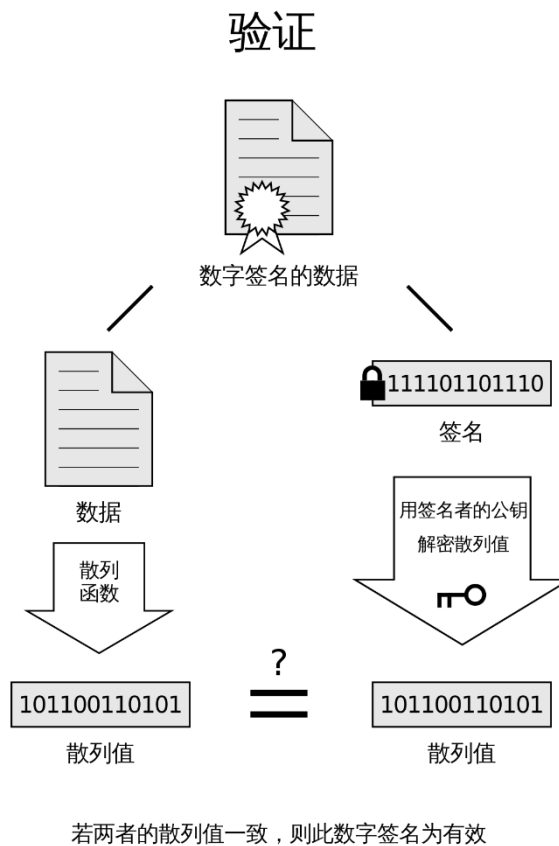
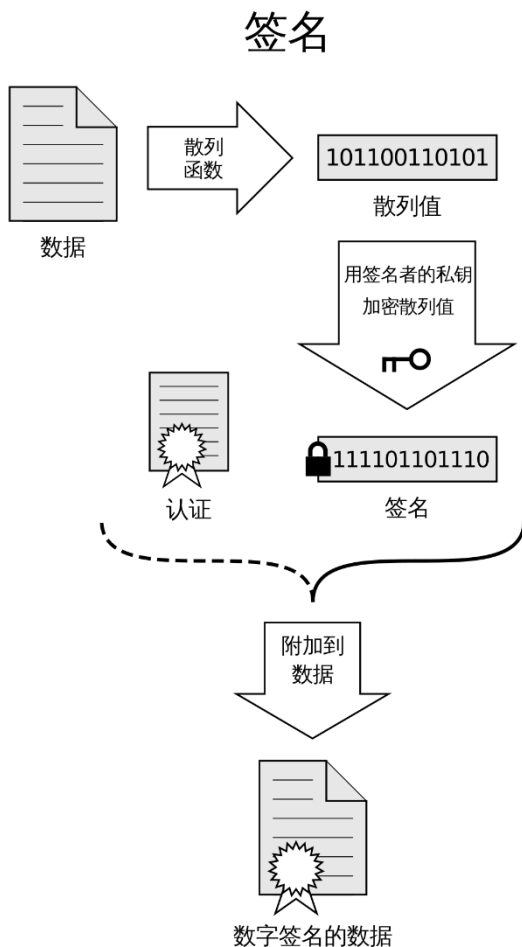
既然 $P^{(p-1)(q-1)} - 1$ 同时被 p 、 q 整除

那么就有 $P^{(p-1)(q-1)} \bmod n = 1, (n = pq)$

$$\text{因此 } C^d \bmod n = P * P^{k(p-1)(q-1)} \bmod n = P$$



现代密码学：数字签名



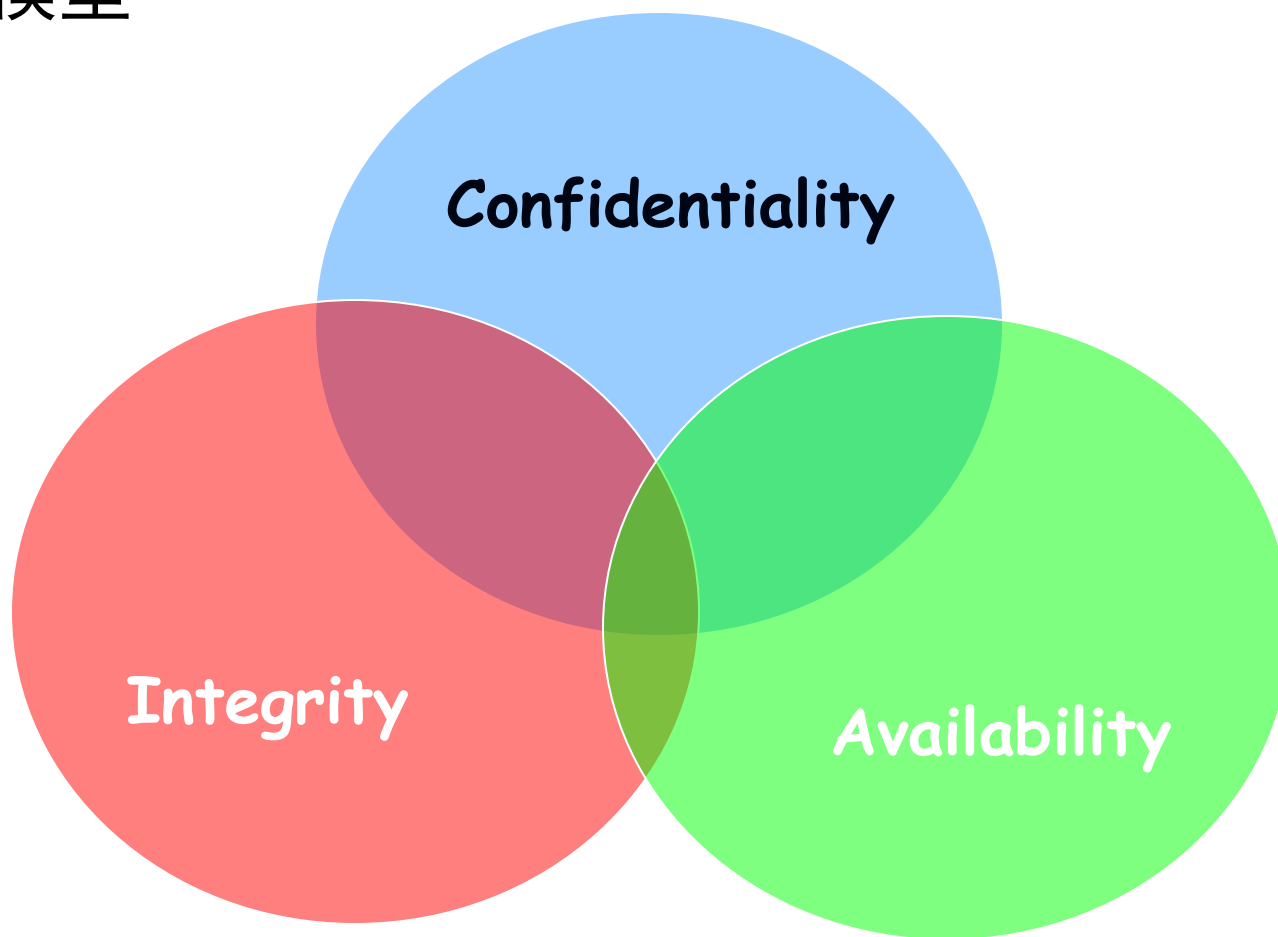
» 主要内容

- 密码学概述
 - 古代密码学
 - 现代密码学
- 信息安全
 - 内涵与外沿
 - 安全威胁与防范

信息安全

什么是信息安全？

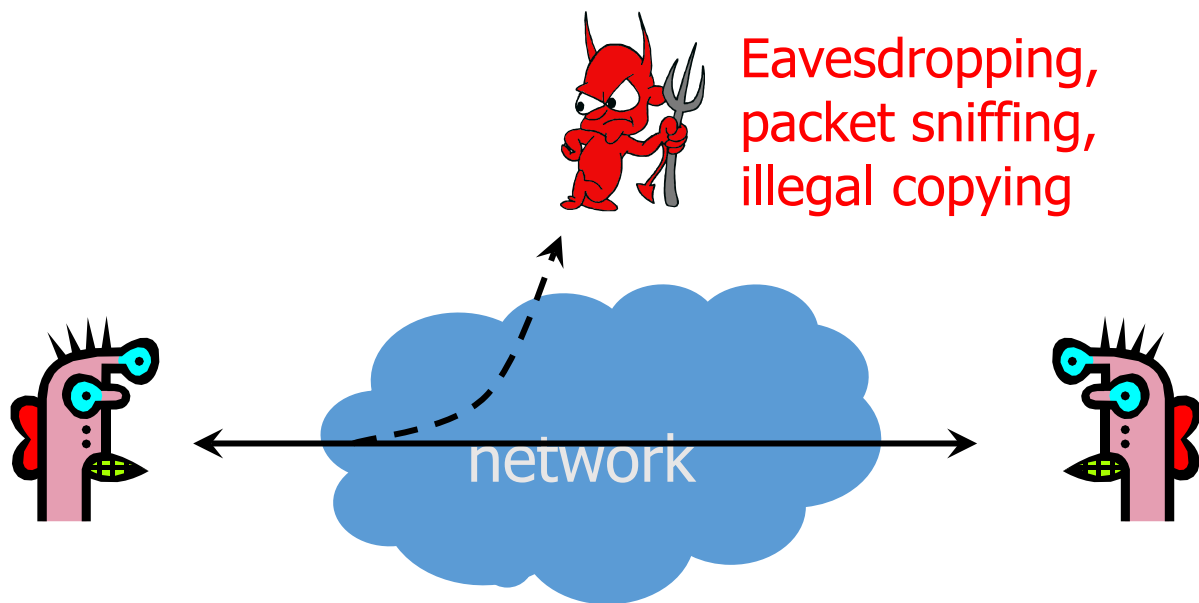
CIA模型



信息安全

保密性(confidentiality)

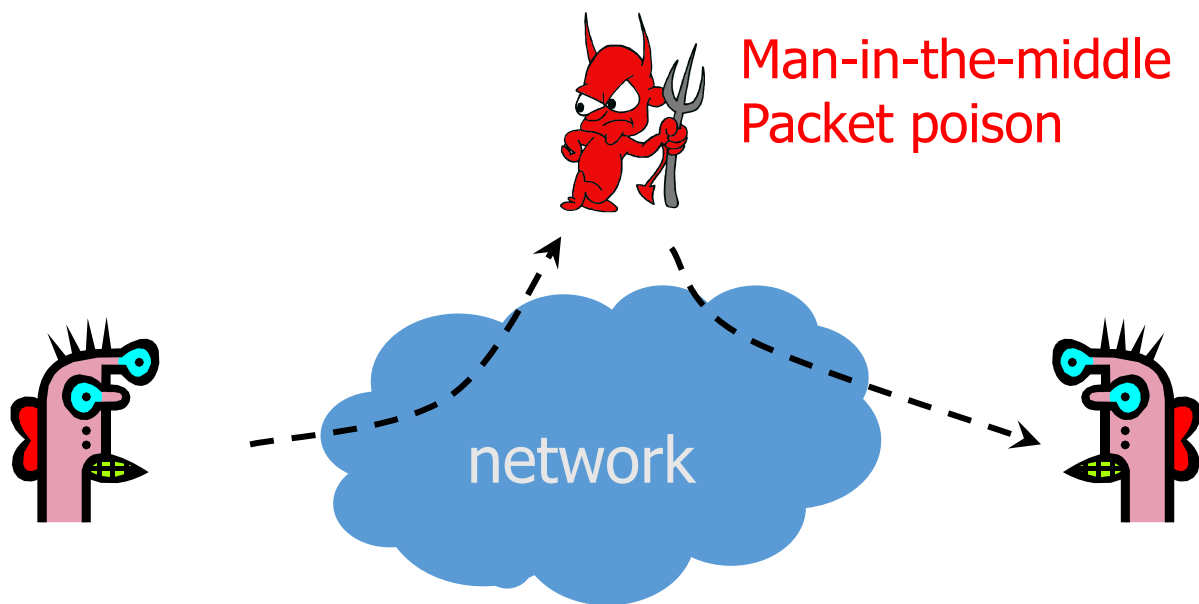
- 保密性 (confidentiality) 是指信息系统防止信息非法泄露的特性，信息只限于授权用户使用，保密性主要通过信息加密、身份认证、访问控制、安全通信协议等技术实现，**信息加密是防止信息非法泄露的最基本手段。**



信息安全

完整性(Integrity)

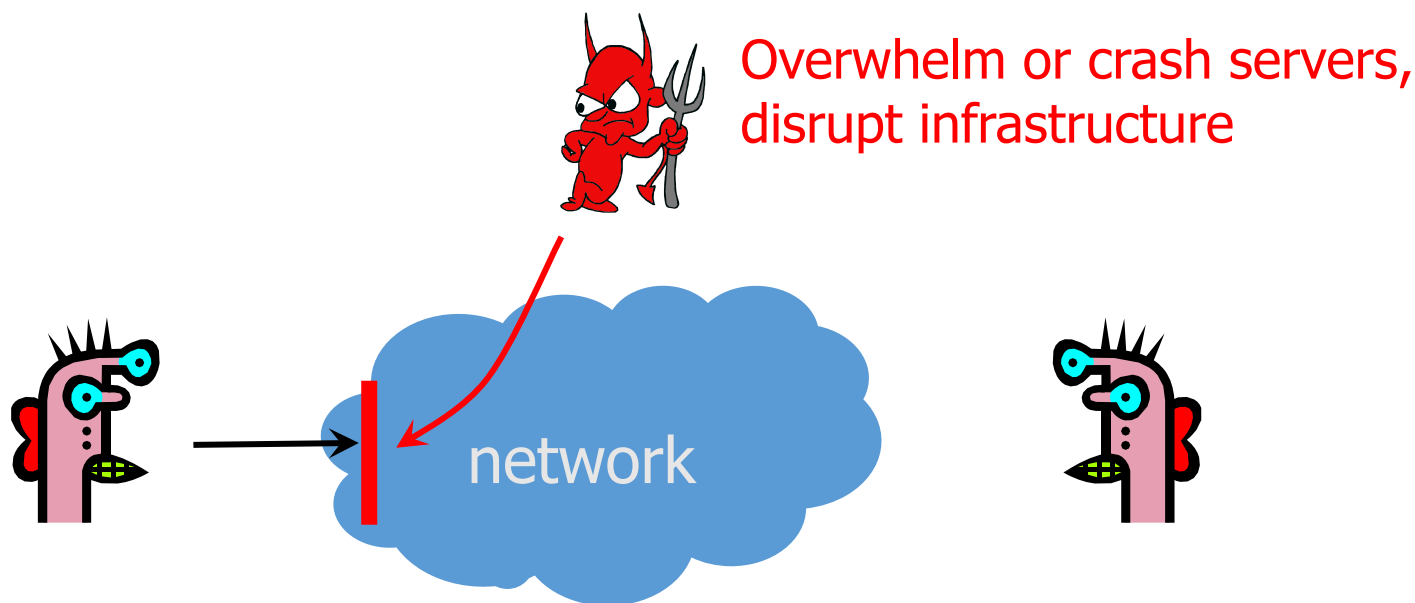
- 完整性 (integrity) 是指在传输、存储信息或数据的过程中，确保信息或数据不被未授权的篡改或在篡改后能够被迅速发现。



信息安全

有效性(Availability)

- **有效性** (Availability) 是指信息资源容许授权用户按需访问的特性，有效性是信息系统面向用户服务的安全特性。信息系统只有持续有效，授权用户才能随时、随地根据自己的需要访问信息系统提供的服务。



信息安全的扩展

- 可鉴别性
- 不可否认性
- 隐私
- 自主可控

» 主要内容

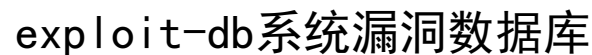
- 密码学概述
 - 古代密码学
 - 现代密码学
- 信息安全
 - 内涵与外沿
 - 安全威胁与防范

黑客入侵方式

- 观衅而动
- 守株待兔
- 社会工程

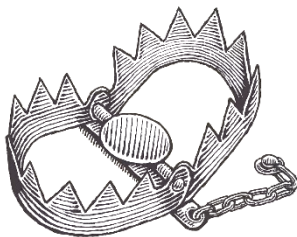
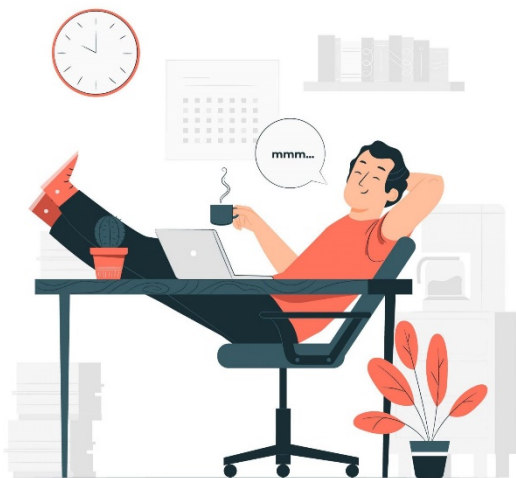
观衅而动

-



守株待兔

- 制造陷阱，无需太多精力便可窃取访问者提交的信息



输入密码你就上当了！

信息安全

社会工程学

- 社会工程学、软硬兼施



用个人信息诈骗



勒索软件

信息安全

防患于未然

主动攻击

及时更新系统，修复系统漏洞
不使用公共接口

虚假WiFi

关闭Wi-Fi的自动连接功能
检查Wi-Fi安全性后再进行连接

恶意软件

不随意安装未知来源的软件
谨慎授予软件权限

钓鱼邮件及网站

不轻易打开未知的链接

信息安全的扩展

- 电信诈骗的危害。
- 网络安全相关法规。
 - 《刑法》第二百八十五条【非法侵入计算机信息系统罪】
 - 《刑法》第二百八十六条【破坏计算机信息系统罪】
 - 《中华人民共和国网络安全法》，2017年6月1日实施。
 - 《中华人民共和国数据安全法》，2021年9月1日起施行。

思考题

1. 那些内容可以作为识别垃圾邮件的特征？
2. 小明是一个程序员，发明了一个非常好用的软件，把软件做成一个安装光盘，安装在Windows系统中就能使用，但是由于他对于安全技术不是很了解，故受到盗版问题的困扰，需要你的帮助。请简述如何设计一个版权保护模块，防止盗版使用软件，方法不限。



西安交通大学
XI'AN JIAOTONG UNIVERSITY

Thank you!

